

Glossary: Understanding Cybersecurity Standards and Audits

Welcome! This alphabetized glossary contains many of the terms you'll find within this course. This comprehensive glossary also includes additional industry-recognized terms not used in course videos. These terms are important for you to recognize when working in the industry, participating in user groups, and participating in other certificate programs.

Term	Definition
Active reconnaissance	Gathers detailed insights by directly engaging with the system.
AES	Advanced Encryption Standard is a specification used to encrypt and protect electronic data.
American Institute of Certified Public Accountants (AICPA)	The national professional organization of Certified Public Accountants (CPAs) in the United States.
Attestation	A comprehensive review and validation by a third-party auditor to confirm that the organization's cybersecurity practices align with specific standards and regulations.
Audit committee	This is part of a company's board of directors that plays a critical role in supervising the integrity of financial reporting, the effectiveness of the internal control systems, compliance with legal and regulatory requirements, and the performance of internal and external audit functions.
COBIT	Control Objectives for Information and Related Technologies is a framework for conducting audits that assess the organization's strategic goals about IT governance, risk management, and the value of IT investments.
Compliance audits	Determines whether an organization adheres to legal, regulatory, and contractual obligations.
Data Loss Prevention (DLP)	A security measure that identifies and helps prevent unsafe sharing, transfer, or use of sensitive data.
Defensive Pen Testing	Focuses on improving the organization's defensive mechanisms by identifying weaknesses within the organization's known environment.
Electromagnetic compatibility (EMC)	Ensures that devices do not emit harmful levels of electromagnetic interference and are resistant to external interference, ensuring reliable operation.
External assessments	Involve independent third-party auditors or regulatory agencies examining the organization's compliance and effectiveness of its control environment.
Federal Information Processing Standards(FIPS 140-3)	Specifications for the security requirements for cryptographic modules.
GDPR	General Data Protection Regulation aims to protect individuals' fundamental rights and freedom, particularly their right to privacy.
Generally Accepted Privacy Principles (GAPP)	A framework intended to assist Chartered Accountants and Certified Public Accountants in creating an effective privacy program for managing and preventing privacy risks.
HDMI	High-Definition Multimedia Interface is an all-digital audio-video interface that transmits uncompressed information to a computer monitor, video projector, digital television, etc.
HIPAA	The Health Insurance Portability and Accountability Act is a 1996 federal law passed by the Department of Health and Human Services to protect patients' personal data from public access.
IEEE 802.3	Defines the standards for Ethernet, a technology for wired LAN networking that enables devices to communicate with each other.
IEEE 802.11	The 802.11 standard, the original wireless specification, was developed by the Institute of Electrical and Electronic Engineers (IEEE). Extensions of the 802.11 standard were given the same number with a letter suffix.
IEEE 802.11 WLAN	A wireless LAN communication standard includes considerations for secure encrypted communication over radio waves, which prevents unauthorized access and ensures data integrity.
IEEE 802.1X	It provides an authentication mechanism for devices that attach to a LAN or WLAN, ensuring that only authorized devices can connect.
IEEE 802.16	Known as WiMAX (Worldwide Interoperability for Microwave Access), it provides guidelines for wireless networking and offers an alternative to traditional cable and DSL connections.
IEEE 1547	Establishes a standard for interconnecting distributed resources with electric power systems, which is critical for the security and efficiency of smart grids.
IEEE 1619	This paper focuses on cryptographic protocols for protecting data on block-oriented storage devices, addressing the need for secure data encryption on hard drives and other storage devices.
IEEE 1686	Specifies security requirements for intelligent electronic devices (IEDs) to be securely managed, operated, and maintained.

IEEE 2700	A series of standards for sensor interfaces related to Internet of Things (IoT) devices ensures secure and reliable sensor operations.
Independent third-party audits	Conducted by external auditors, these assessments offer an objective analysis of the organization's operations, security practices, and compliance with industry standards.
Information Security Management Systems (ISMS)	Offers a framework for managing and protecting sensitive information.
Institute of Electrical and Electronics Engineers (IEEE)	A professional association dedicated to advancing technology for the benefit of humanity.
Integrated Pen Testing	Combines offensive and defensive strategies to assess the security posture comprehensively.
Internal audits	Serve as an in-depth examination of its internal controls, methods, and procedures to ensure compliance with regulatory requirements, internal policies, and industry best practices.
International Organization for Standardization (ISO)	A worldwide federation of national standards bodies from over 160 countries.
ISACA	Information Systems Audit and Control Association is a global nonprofit focusing mainly on IT governance.
ISO 27001	It is a family of international standards for information security.
NIST Cybersecurity Framework (CSF)	This is a vital tool for organizations aiming to bolster their cybersecurity posture. It offers a comprehensive set of guidelines that can be tailored to fit any organization's size, risk profile, and cybersecurity needs.
NIST	The National Institute of Standards and Technology, an agency of the U.S. Department of Commerce, is a bedrock of the scientific community. It provides the measurements, standards, and technology to drive innovation and economic growth.
NIST SP 800-30	Guide for conducting risk assessments.
NIST SP 800-34	Contingency Planning Guide for Federal Information Systems.
NIST SP 800-37	A comprehensive guide provides a process integrating security, privacy, and risk management activities into the system development life cycle.
NIST SP 800-61	Computer Security Incident Handling Guide.
NIST SP 800-63	Guidelines on digital identity covering identity proofing, authentication, and federation standards.
NIST SP 800-88	Guidelines for media sanitization.
OAuth	Open Authentication is an open-standard authorization protocol or framework that allows applications to secure designated access.
Offensive Pen Testing	It mimics the actions of attackers aiming to breach the organization's defenses without prior knowledge of the internal systems (unknown environment) or with limited information (partially known environment).
OpenID	A decentralized authentication protocol that allows users to authenticate with multiple websites using a single set of credentials, eliminating the need for separate usernames and passwords for each website.
OWASP ASVS	OWASP Application Security Verification Standard is a framework for assessing the security of web applications and services.
OWASP Cheat Sheet Series	A collection of concise, high-value documents on various application security topics created by seasoned security professionals.
OWASP MASVS	The Open Web Application Security Project Mobile Application Security Verification Standard is a framework to establish a security baseline for mobile applications.
OWASP	Open Web Application Security Project is a nonprofit organization focused on making software more secure.
OWASP SAMM	The OWASP Software Assurance Maturity Model is an open framework designed to help organizations formulate and implement a software security strategy that integrates easily into their existing Software Development Lifecycle (SDLC).
OWASP Testing Guide	A comprehensive manual that provides a framework for the security testing web applications and services.
OWASP Top 10	A widely recognized document that outlines the ten most critical web application security risks, serving as a guideline for developers and security professionals to understand and mitigate prevalent vulnerabilities.
OWASP SAMM	The OWASP Software Assurance Maturity Model is an open framework designed to help organizations formulate and implement a software security strategy that integrates easily into their existing Software Development Lifecycle (SDLC).
Passive reconnaissance	Gathers information about the target without directly interacting with the systems.

PCI DSS	Payment Card Industry Data Security Standard is an information security standard designed to reduce payment card fraud by increasing security controls around cardholder data.
Penetration testing	A specialized type of audit designed to assess the security of an organization's information systems by simulating an attack from malicious outsiders (offensive) or insiders (defensive).
PGP	Pretty Good Privacy, a security program used to decrypt and encrypt email and authenticate email messages through digital signatures and file encryption.
Physical Pen Testing	Evaluates an organization's physical security measures to prevent unauthorized access to sensitive areas or information.
Quality of Service (QoS)	Specify prioritization schemes to manage traffic and ensure critical data, such as real-time voice and video, receives higher priority over less time-sensitive information.
Regulatory examinations	Are assessments performed by government agencies or regulatory bodies to confirm compliance with applicable laws and regulations.
Risk IT	Provides a detailed, comprehensive view of all risks related to the use of information technology.
Role-Based Access Control (RBAC)	Restricts network access based on a person's role within an organization.
SAML	Security Assertion Markup Language, a standardized way to tell external applications and services that users are who they say they are.
SATA	Serial Advanced Technology Attachment or Serial ATA an interface used for connecting various devices like SSDs, hard disks, optical devices, and more with the motherboard.
Secure sockets layer and transport layer security (SSL/TLS)	A protocol for secure web browsing.
Security and Privacy Controls for Federal Information Systems and Organizations (NIST SP 800-53)	Provides a comprehensive set of controls for protecting federal information systems and organizations.
Security audit	A comprehensive review of a company's security architecture.
Self-assessments	Enable an internal review of performance and compliance levels before external audits, acting as a self-check mechanism to identify and rectify any discrepancies or areas of concern.
Service level agreement (SLA)	A document that outlines a commitment between a service provider and a client, including service details, the standards the provider must adhere to, and the metrics to measure the performance.
SHA-256	Secure Hash Algorithm 256-bit is used for cryptographic security.
SHA-3	NIST released Secure Hash Algorithm 3, the latest member of the Secure Hash Algorithm family of standards.
SOC	Service Organization Control, a voluntary compliance standard for service organizations developed by the American Institute of CPAs (AICPA).
SOC 1	A report evaluates the internal controls related to financial reporting within a service organization.
SOC 2	A report focuses on non-financial controls crucial for an organization's oversight, vendor management, risk management, and regulatory compliance.
SOC 3	A report intended for public dissemination, allowing organizations to share their control environment without revealing detailed findings.
SOX	Sarbanes-Oxley Act, a 2002 law Congress passed to increase accountability in the financial sector.
Trust Services Criteria (TSC)	The SOC 2 report includes security, availability, processing integrity, confidentiality, and privacy criteria.
USB	Universal Serial Bus is a common platform for communication between devices and a host controller such as a PC (computer).
Val IT	A governance framework that can be used to create business value from IT investments.
WiFi	Wireless Fidelity, a wireless technology standard for wireless Internet access.



Skills Network